

Ethics, Privacy, and Regulation in Informatics

Laboratórios de Sistemas e Serviços

Mário Antunes

Universidade de Aveiro

2026

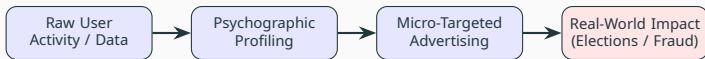
Ethics in Informatics

The Impact of Collecting and Sharing Data i

- **Data is Power:** In the digital age, “Money is one thing, but data is power”. Data shapes public discourse, influences markets, and governs individual behaviors.
- **Real-world Consequences:**
 - **Political Manipulation:** Data analytics firms (e.g., Cambridge Analytica) have used personal data to construct psychographic profiles, allowing them to micro-target voters and potentially influence democratic outcomes like the Brexit referendum and the 2016 US presidential election.
 - **Financial Fraud:** Leaked or mishandled data can lead to identity theft and severe financial loss. Financial institutions often shift liability by blaming users for “phishing” or negligence despite systemic security vulnerabilities in their own systems.

The Impact of Collecting and Sharing Data ii

- **The Ethical Imperative:** As developers, we must recognize that behind every data point is a human being with fundamental rights. Software decisions can impact livelihoods, safety, and dignity.

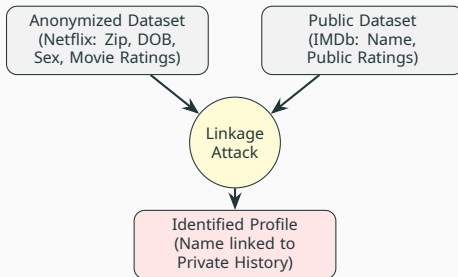


Indirect Identification i

- **The Myth of “Anonymous” Data:** Removing direct identifiers (like names, IDs, or emails) is often highly insufficient to protect individual identity.
- **Definition:** A person is “identifiable” if they can be distinguished not just directly, but **indirectly** by combining auxiliary factors like location, age, gender, zip code, or physical characteristics.
- **Quasi-Identifiers:** Attributes that do not uniquely identify a person on their own, but can do so when linked with other databases.
- **Re-identification Risks:**
 - Studies show that **87%** of the US population could be uniquely identified using only three data points: **Zip Code, Birth Date, and Sex.**

Indirect Identification ii

- **Example:** The “Netflix Prize” dataset was anonymized by removing names. However, researchers re-identified specific users and uncovered their private movie viewing history by cross-referencing and linking anonymous movie ratings with public IMDb profiles.
- **Lesson:** Always assume data can be re-linked. As computational power increases, the term “anonymized” should be treated with extreme technical skepticism.

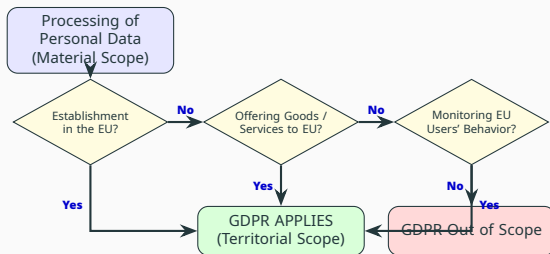


RGPD (GDPR) and Privacy Assurance

What is RGPD? i

- **Regulation (EU) 2016/679:** The General Data Protection Regulation (RGPD/GDPR), which went into effect on May 25, 2018.
- **Core Philosophy:** Privacy is a **fundamental human right**, not a luxury. The user owns their data; organizations are merely temporary stewards.
- **Scope of Application:**
 - **Material Scope:** Applies to the processing of personal data wholly or partly by automated means, or structured manual filing systems.
 - **Territorial Scope (Extra-territorial Reach):** Applies to *any* entity processing data of EU residents, regardless of where the processing takes place (e.g., a US-based cloud service targeting EU users must fully comply with GDPR).

What is RGD? ii



The Level of Privacy We Must Provide i

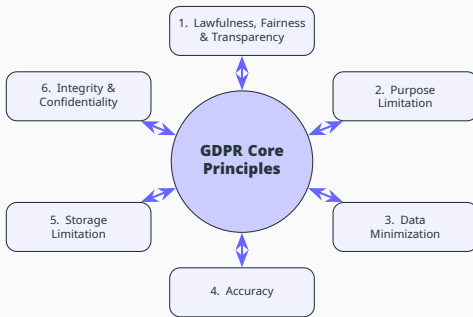
Developers must ensure systems strictly adhere to these **6 + 1 key principles**:

1. **Lawfulness, Fairness, & Transparency**: No hidden processing. Users must know exactly how and why their data is processed via clear privacy policies.
2. **Purpose Limitation**: Data collected for “Project A” cannot be reused for “Project B” or ad profiling without obtaining new, specific consent.
3. **Data Minimization**: Collect only what is strictly necessary. Do not ask for phone numbers if you only require an email address.
4. **Accuracy**: Data must be correct and up-to-date, with easy-to-use self-service portals for users to rectify discrepancies.

The Level of Privacy We Must Provide ii

5. **Storage Limitation:** Delete data when it is no longer needed. Implement automatic database purges for expired accounts.
6. **Integrity & Confidentiality:** Protect data against unauthorized access, loss, or leakage using encryption, strict access controls, and robust hashing (e.g., bcrypt).
7. **Accountability:** The controller must be able to *demonstrate* compliance through detailed technical documentation and audit logs.

The Level of Privacy We Must Provide iii



7. Accountability (Responsabilidade)

Privacy by Design & Default i

- **By Design:** Privacy measures must be embedded directly into the architecture of the software from the very start, rather than added as a patch later.
 - *The 7 Foundational Principles:* Proactive, preventive, default settings, embedded design, full functionality (positive-sum), end-to-end security, and respect for user privacy.
- **By Default:** The strictest privacy settings should apply automatically without user intervention (e.g., a social media profile should be private by default, and location tracking should be opt-in).
- **Accountability:** The controller must maintain thorough logs and technical documentation to prove compliance to supervisory authorities at any time.

Privacy by Design & Default ii

Privacy by Design

Embedded in Lifecycle
(Requirements →
Design → Code)

Full Functionality
(Positive-Sum:
No Trade-offs)

End-to-End Security
(Lifecycle Protection)

Privacy by Default

Strictest Settings Apply
Automatically

Data Minimization
by Default

User Choice Needed
to Share More

European AI Act

Overview of the AI Act i

- **Risk-Based Approach:** The AI Act categorizes artificial intelligence systems based on the potential risk they pose to safety, livelihoods, and fundamental human rights.
- **The 4 Risk Categories:**
 - **Unacceptable Risk:** Immediate ban (e.g., social scoring, cognitive behavioral manipulation, and real-time remote biometric identification in public spaces by law enforcement, with minor exceptions).
 - **High Risk:** Permitted but strictly regulated (e.g., AI in education, CV screening for employment, critical infrastructure, healthcare diagnostics).
 - **Limited Risk:** Transparency obligations. Users must be explicitly informed they are interacting with AI (e.g., chatbots, deepfakes, AI-generated text).
 - **Minimal/No Risk:** Unregulated (e.g., standard spam filters, AI in video games).

Overview of the AI Act ii



Banned: Social scoring, real-time biometrics (with exceptions)

Regulated: AI in health, CV screening, critical infrastructure

Transparency: Chatbots, deepfakes, AI-generated content

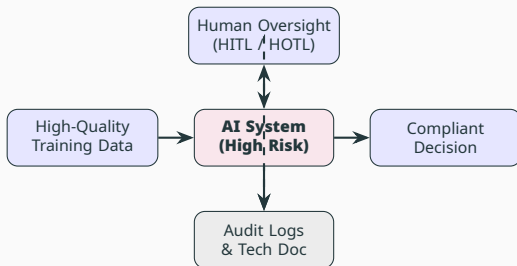
Unregulated: Spam filters, gaming, basic analytics

Privacy and Auditability in AI i

- **Relation to Privacy:** High-risk AI systems must operate on high-quality, representative, and unbiased training data to prevent discrimination. They must adhere strictly to GDPR principles such as data governance and security.
- **Auditability Requirements:**
 - **Logging:** Systems must automatically record operational events (logs) to trace their functioning and detect potential biases or failures in real-time.
 - **Technical Documentation:** Developers must construct and maintain detailed documentation describing the algorithm's architecture, training process, and validation criteria.
 - **Human Oversight:** High-risk systems must be designed to accommodate direct human supervision to override or shut down decisions:

Privacy and Auditability in AI ii

1. *Human-in-the-loop (HITL)*: Active human approval for every decision.
2. *Human-on-the-loop (HOTL)*: Active human monitoring with intervention capabilities.
3. *Human-in-command (HIC)*: Oversight over the system's operational scope and lifecycle.

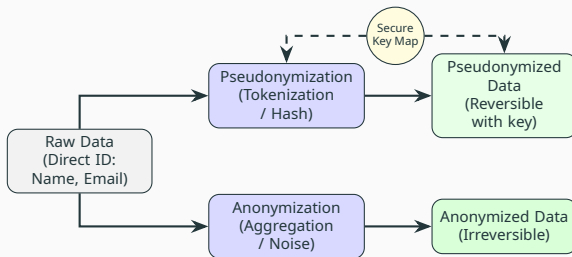


How to Protect Ourselves and Our Users

Guaranteeing Protection: Technical Measures i

- **Pseudonymization:** Reversible processing of data such that it can no longer be attributed to a specific subject without using auxiliary information (keys), which must be kept strictly separated and protected.
- **Anonymization:** Irreversible removal of all direct and indirect identifiers.
 - *Legal Note:* Truly anonymized data falls completely outside the scope of GDPR. However, mathematically proving complete, irreversible anonymity (e.g., against future linkage attacks) is extremely difficult.
- **Encryption:** The mandatory industry standard for sensitive data:
 - *In Transit:* Protecting data flowing over networks (TLS 1.3).
 - *At Rest:* Protecting stored files and databases (AES-256).

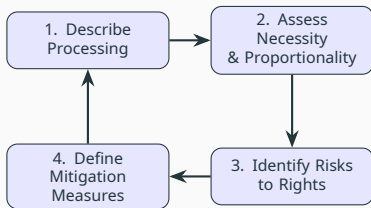
Guaranteeing Protection: Technical Measures ii



- **Data Protection Impact Assessment (DPIA/AIPD):**
 - Mandatory prior to launching any high-risk processing project (e.g., public space surveillance, large-scale health data processing).
 - **The 4 Essential Steps:**
 1. **Describe:** Document the processing operations and the purposes.
 2. **Assess:** Evaluate the necessity and proportionality of the data collected.
 3. **Identify:** Map out potential risks to user rights and freedoms.
 4. **Define:** Establish technical and organizational measures to mitigate identified risks.

Guaranteeing Protection: Process Measures ii

- **Consent Management:** Under GDPR, consent must be **free, specific, informed, and explicit**. Pre-ticked checkboxes or hidden clauses in terms of service are legally invalid. Consent must be as easy to withdraw as it is to give.



Protecting Ourselves (As Professionals) i

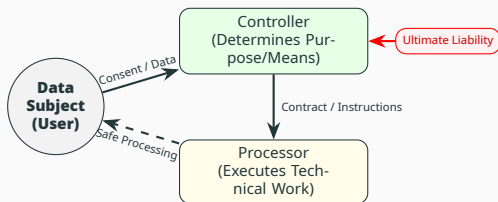
- **Clear Liability Rules:**

- **Controller (Responsável pelo Tratamento):** The entity that determines the “why” and “how” of data processing. Bears ultimate legal liability under GDPR.
- **Processor (Subcontratante):** The entity that processes personal data on behalf of the controller. Handles technical implementation.
- *Developer Duty:* Even if acting under instructions, developers must warn controllers if instructions violate data protection laws and ensure software is secure.

- **Continuous Vigilance:**

- Monitor re-identification risks as datasets grow (big data linkages).
- Maintain awareness of legal framework adjustments for **International Data Transfers** (e.g., standard contractual clauses - SCCs, and adequacy frameworks when using US-based servers).

Protecting Ourselves (As Professionals) ii



1. **Official Legal Texts:**

- [GDPR \(EU 2016/679\) Full Text](#)
- [European AI Act Text](#)

2. **Handbooks:**

- [Handbook on European Data Protection Law](#) (FRA/Council of Europe).

3. **Institutional Guidance:**

- Data Protection Officer (DPO) contacts at your institution [here](#)
- CNPD (Comissão Nacional de Proteção de Dados) [guidelines](#).